

YOURDAY

公网部署计划表

从服务器准备、安全整改到上线验收与长期运维

目标	将 YourDay 安全、稳定地部署到公网，并建立可备份、可监控、可更新的生产环境。
推荐架构	域名 → Caddy (HTTPS) → React 前端 + /api → Node/Express → SQLite
首要动作	先准备服务器、域名和 SSH 登录；随后由我完成代码整改与技术部署。

执行原则

01	先消除默认弱密码和隐私文件风险，再开放公网。
02	生产密钥只存服务器环境变量，不进入代码仓库。
03	数据库与附件按运行数据管理，并建立异地备份。

执行路线总览

严格按依赖顺序推进。服务器与域名完成后，代码整改、部署、验证和运维配置可以连续执行。

阶段	主要成果	主要负责人
第一阶段 确定上线方案	确定服务器地区；准备域名；配置安全的 SSH 登录	你 / 你操作，我指导
第二阶段 上线前安全整改	移除默认弱密码；清理仓库中的上传文件；修正生产部署配置	我 / 你决定，我执行
第三阶段 本地发布验证	构建并测试生产版本	我
第四阶段 部署服务器	初始化服务器；部署代码和生产环境变量	我（经你授权） / 我
第五阶段 域名和 HTTPS	配置 DNS；配置 Caddy 和 HTTPS	你操作，或我代操作 / 我
第六阶段 数据迁移	选择并迁移数据	你决定，我执行
第七阶段 验收和运维	完整功能验收；建立自动备份；建立监控和更新流程	我检查，你确认 / 我 / 我配置，你接收通知

关键依赖

服务器 → SSH → 安全整改 → 本地构建 → 服务器部署 → DNS → HTTPS → 数据迁移 → 验收 → 备份与监控。

第一阶段 | 确定上线方案

01	确定服务器地区	负责人：你
要做什么	• 大陆用户优先：选择中国大陆服务器并准备 ICP 备案 • 快速测试：可选择中国香港或新加坡服务器 • 建议规格：Ubuntu 24.04、2 核 2-4 GB、50 GB 以上磁盘	
为什么	服务器地区决定备案要求、访问速度和整体成本。	
完成标准	☐ 服务器地区已确定 ☐ 云服务器已购买 ☐ 公网 IP 已取得	

02	准备域名	负责人：你
要做什么	• 购买或选定域名 • 确定正式地址，例如 yourday.example.com • 大陆服务器按要求完成 ICP 备案	
为什么	域名用于公网访问，也是自动签发 HTTPS 证书的前提。	
完成标准	☐ 可管理域名 DNS ☐ 正式访问地址已确定 ☐ 备案已完成，或所在地区不要求备案	

03	配置安全的 SSH 登录	负责人：你操作，我指导
要做什么	• 在本机生成 SSH 密钥 • 将公钥添加到服务器 • 确认本机可免传递密码地登录服务器	
为什么	后续安装、部署和更新都通过 SSH 完成；密钥登录比传递密码或私钥安全。	
完成标准	☐ 本机可通过 SSH 登录 ☐ 未在聊天或代码中泄露密码、私钥	

第二阶段 | 上线前安全整改

04 移除默认弱密码		负责人：我
要做什么	• 修改后端初始化逻辑 • 禁止生产环境创建 root / 123456 • 通过安全初始化方式创建管理员 • 检查 JWT 密钥强度	
为什么	固定默认密码在公网环境中极易被扫描和利用，必须在发布前消除。	
完成标准	☐ 生产环境不存在固定默认密码 ☐ JWT 使用随机强密钥 ☐ 认证流程通过测试	

05 清理仓库中的上传文件		负责人：你决定，我执行
要做什么	• 确认现有图片、音频是否包含私人数据 • 将运行时上传目录加入 Git 忽略 • 取消 Git 对现有上传文件的跟踪 • 决定是否单独迁移这些文件	
为什么	运行数据不应进入代码仓库；公开仓库尤其可能造成隐私泄露。	
完成标准	☐ 新上传文件不再进入 Git ☐ 现有文件迁移方案已确定 ☐ 私人内容不会意外公开	

06 修正生产部署配置		负责人：我
要做什么	• 统一服务器目录为 /opt/yourday • 修正 PM2、Caddy 和备份脚本路径 • 使用同一域名提供网页和 /api • 补齐 SPA 路由回退	
为什么	现有文档的克隆目录与配置路径不一致，双域名配置也与前端的同域 API 请求不匹配。	
完成标准	☐ 生产路径一致 ☐ /api 正确转发 ☐ 刷新前端路由不会出现 404	

第三阶段 | 本地发布验证

07 构建并测试生产版本		负责人：我
要做什么	• 按锁文件安装依赖 • 构建 React 前端 • 以生产模式启动后端 • 测试登录、待办、日记和上传 • 确定本次发布所包含的代码修改	
为什么	先在本地证明代码可构建、可运行，避免把依赖或类型错误带到生产服务器。	
完成标准	□ 前端构建成功 □ 后端健康检查正常 □ 核心功能通过 □ 发布版本已明确	

第四阶段 | 部署服务器

08	初始化服务器	负责人：我（经你授权）
要做什么	• 更新系统 • 安装 Node.js、Git、Caddy、SQLite、PM2 • 配置防火墙 • 创建应用、日志和数据目录	
为什么	为应用准备稳定、安全并且可维护的运行环境。	
完成标准	□ 依赖安装完成 □ 仅开放 SSH、80、443 □ Node 服务端口未直接暴露公网	

09	部署代码和生产环境变量	负责人：我
要做什么	• 从 GitHub 拉取代码 • 安装前后端依赖并构建前端 • 配置生产 .env 和随机 JWT 密钥 • 使用 PM2 启动后端并设置开机自启	
为什么	密钥不能写入 Git；PM2 可保持服务常驻，并在异常退出或重启后恢复。	
完成标准	□ 后端持续运行 □ 本机健康检查正常 □ 服务器重启后应用自动恢复 □ 密钥未进入仓库	

第五阶段 | 域名和 HTTPS

10 配置 DNS		负责人：你操作，或我代操作
要做什么	• 添加 A 记录：正式域名指向服务器公网 IP • 等待 DNS 解析生效	
为什么	DNS 让访问者通过域名找到服务器，也是 HTTPS 自动签发的基础。	
完成标准	□ 域名解析到正确 IP □ 外部网络能够解析该域名	

11 配置 Caddy 和 HTTPS		负责人：我
要做什么	• 将 /api/* 反向代理到 Express • 提供 React 静态文件 • 配置 SPA 路由回退 • 开启自动 HTTPS 和 HTTP 跳转 • 加入基础安全响应头	
为什么	Caddy 作为公网入口统一处理证书、网页和 API；后端无需直接暴露。	
完成标准	□ HTTPS 首页可访问 □ HTTPS 健康检查正常 □ 证书有效 □ 前端刷新不出现 404	

第六阶段 | 数据迁移

12 选择并迁移数据		负责人：你决定，我执行
要做什么	• 三选一：全新数据库、完整迁移、仅迁移数据库 • 安全处理 SQLite WAL 后迁移 • 迁移必要的图片和音频 • 设置正确目录权限	
为什么	SQLite 数据库和上传文件属于运行数据，仅重新拉取代码无法恢复它们。	
完成标准	□ 数据库位于持久化目录 □ 账号和业务数据符合预期 □ 附件访问正常 □ 文件权限正确	

第七阶段 | 验收和运维

13 完整功能验收		负责人：我检查，你确认
要做什么	• 测试注册、登录和管理员账号 • 测试待办、日历、日记和上传 • 检查手机端表现 • 审查错误日志与未授权访问	
为什么	健康检查正常不代表业务全部正常，必须按真实用户流程验收。	
完成标准	□ 核心流程全部通过 □ 没有持续 4xx/5xx 异常 □ 默认弱密码已不存在	

14 建立自动备份		负责人：我
要做什么	• 每天执行 SQLite 在线备份 • 保留最近 30 天 • 同步到 COS/OSS 或另一台服务器 • 执行一次恢复测试	
为什么	只有异地且可恢复的备份，才能应对服务器损坏、误删除或数据库异常。	
完成标准	□ 每日自动备份 □ 备份不只保存在原服务器 □ 已验证可以恢复	

15 建立监控和更新流程		负责人：我配置，你接收通知
要做什么	• 定时检查 /api/health • 监控进程和磁盘空间 • 保留应用与访问日志 • 固化拉取、构建、重启和检查流程	
为什么	监控能及时发现故障；标准更新流程能减少停机和手工操作错误。	
完成标准	□ 异常时可以收到通知 □ 日志能够定位问题 □ 更新和回滚流程明确	

启动部署前，需要提供的信息

服务器	公网 IP、SSH 用户名、操作系统；确认当前电脑能够通过 SSH 登录。
域名	正式域名、备案状态、DNS 服务商。
仓库	GitHub 仓库公开或私有；私有仓库需准备 Deploy Key。
数据	选择全新、完整迁移或仅迁移数据库；确认上传文件是否包含隐私内容。
小程序	是否同时上线；密钥不要通过聊天发送。
发布范围	只发布 frontend + backend，或包含当前 miniprogram 修改。

建议现在先完成

1	购买或确认云服务器
2	确定正式域名和备案方案
3	打通当前电脑到服务器的 SSH 密钥登录

完成这三项后，即可进入安全整改和实际部署。涉及实名认证、ICP备案、购买资源或输入秘密密钥的步骤由你本人操作，其余技术工作可由我完成。